UNIVERSIDAD DE SEVILLA

Escuela Técnica Superior de Ingeniería Informática

Seguridad en Sistemas de Información / Ingeniería de Seguridad

PROYECTO DE AUDITORÍA Y BASTIONADO (PAI-3)

VULNAWEB: Auditoría de Seguridad Integral en Sistemas Informáticos, Navegadores Web, Dispositivos Móviles y Aplicaciones Web

Marco de Cumplimiento: Esquema Nacional de Seguridad (ENS - Categoría Alta), CIS Benchmarks, NIST SP 800-115, OWASP Top 10 y OWASP API Security Top 10:2023

Entidad Auditada:
Universidad Pública U-Secure
En colaboración con INSEGUS

Equipo de Seguridad:
Security Team 2 (ST-02)

Miembros del Equipo:
Konstantinos Peridis
Raimundo García Pérez
Luis de Alarcón Conradi

Convocatoria / Curso:
Curso Académico 2026/2027

Sevilla, Noviembre de 2026

Índice

1. Resumen Ejecutivo **2**

2. Auditoría y Bastionado de Sistemas Informáticos (Endpoints Linux) **2**
2.1. Descripción de los Sistemas Analizados y Herramientas de Análisis . . . 2
2.2. Plan de Pruebas y Resultados Comparativos (Línea Base vs. Post-Bastionado) . . . 2
2.3. Medidas Técnicas Implementadas y Justificación de Exclusiones . . . 3
2.4. Conclusiones del Bastionado de Endpoints . . . 4

3. Análisis y Bastionado de Navegadores Web Corporativos **4**
3.1. Descripción del Sistema Analizado y Modelo de Despliegue . . . 4
3.2. Directivas Corporativas Implementadas y Plan de Pruebas . . . 4
3.3. Conclusiones y Trazabilidad de Robustecimiento . . . 4

4. Auditoría de Seguridad de Dispositivos Móviles (BYOD) **4**
4.1. Descripción de los Sistemas Móviles y Entorno de Evaluación (BYOD Físico y AVD Virtual) . . . 4
4.2. Matriz de Evaluación de Postura y Plan de Pruebas . . . 5
4.3. Medidas Correctoras Ejecutadas y Conclusiones . . . 5

5. Auditoría de Plataformas Web y APIs (DAST y OWASP API Security 2023) **5**
5.1. Descripción de la Plataforma Web y Herramientas DAST . . . 6
5.2. Trazabilidad de Tráfico Cifrado HTTPS (OWASP ZAP) . . . 7
5.3. Intercepción y Manipulación de Peticiones con Breakpoint (MitM) . . . 7
5.4. Testeo de Inyecciones Automatizadas con ZAP Fuzzer (`jbrofuzz`) . . . 7
5.5. Evaluación Detallada de las 3 Vulnerabilidades Críticas (OWASP Top 10 y OWASP API 2023) . . . 7
5.5.1. Vulnerabilidad 1: Inyección SQL y Exfiltración de Base de Datos (OWASP A03:2021 / API1:2023 & API3:2023) . . . 7
5.5.2. Vulnerabilidad 2: Cross-Site Scripting Reflejado / DOM (OWASP A03:2021 / API8:2023) . . . 9
5.5.3. Vulnerabilidad 3: Path Traversal con Poison Null Byte (OWASP A01:2021 / API1:2023) . . . 9
5.6. Plan Formal de Mitigación Defensiva . . . 9
5.7. Conclusiones de la Auditoría Web y API . . . 10

6. Referencias Normativas y Bibliográficas **10**

7. Anexos y Evidencias Técnicas **10**

1 Resumen Ejecutivo

En el marco del Plan Director de Seguridad de la Información de la Universidad Pública U-Secure y en colaboración con el consorcio INSEGUS, el equipo auditor de seguridad **Security Team 2 (ST-02)** ha ejecutado un proyecto integral de auditoría de seguridad técnica, evaluación de vulnerabilidades y diseño de planes de bastionado y remediación. El alcance operacional del proyecto abarca cuatro dominios estratégicos de la infraestructura universitaria:

1. **Auditoría y Bastionado de Endpoints Linux:** Evaluación de la postura de seguridad de 2 estaciones de trabajo corporativas (Personal Docente e Investigador – PDI y Personal Técnico, de Gestión y de Administración y Servicios – PTGAS) mediante **Lynis v3.1.6**, alcanzando un índice de endurecimiento (*Hardening Index*) superior a 70 puntos (≥ 70), en cumplimiento estricto de la política de seguridad del cliente.
2. **Bastionado de Navegadores Web Corporativos:** Definición y despliegue automatizado de directivas empresariales centralizadas (`policies.json` para Mozilla Firefox y Google Chrome/Chromium) para neutralizar vectores de exfiltración de credenciales, forzar DNS-over-HTTPS (DoH), activar modo HTTPS-Only e inhabilitar protocolos legacy.
3. **Auditoría de Postura en Dispositivos Móviles (BYOD):** Evaluación rigurosa de dos dispositivos móviles (terminal físico personal **Google Pixel 6a** auditado bajo estrictos protocolos de sanitización y privacidad, y un dispositivo emulado oficial **Android AVD API 30**), auditando control de orígenes desconocidos, ausencia de rooting/jailbreak, gestión de parches, seguridad Wi-Fi/Bluetooth, escaneo de malware y permisos abusivos.
4. **Pentesting Web, Fuzzing y Auditoría DAST (OWASP Top 10 y OWASP API Security 2023):** Despliegue de un entorno de pruebas con proxy interceptor (**OWASP ZAP 2.14** en puerto 8081) y plataforma web universitaria vulnerable (**Juice Shop / VulnaWeb**). Se demostró trazabilidad de tráfico HTTPS, intercepción y alteración de parámetros en memoria mediante Breakpoints (MitM), ejecución de pruebas automatizadas con el **ZAP Fuzzer** utilizando el diccionario de inyecciones SQL `jbrofuzz`, explotación demostrada de 3 vulnerabilidades críticas (Inyección SQL con exfiltración de base de datos, XSS reflejado y Path Traversal con byte nulo), y diseño de un plan formal de mitigación defensiva con código seguro.

Todos los hallazgos han sido validados con logs originales, capturas de pantalla, volcados de tráfico y scripts de remediación reproducibles entregados en el paquete técnico `PAI3-ST02.zip`.

2 Auditoría y Bastionado de Sistemas Informáticos (Endpoints Linux)

2.1 Descripción de los Sistemas Analizados y Herramientas de Análisis

En cumplimiento del requerimiento de auditar al menos dos sistemas informáticos universitarios, se evaluaron dos puestos representativos:

- **Endpoint 1 (Puesto PDI Docente/Investigador):** Sistema Linux Ubuntu 22.04 LTS (x86_64), estación de trabajo dedicada a gestión de calificaciones, acceso a plataformas docentes y computación investigadora.
- **Endpoint 2 (Puesto PTGAS Gestión Administrativa):** Sistema Debian 12 Bookworm (x86_64), estación de trabajo administrativa de secretaría encargada del procesamiento de expedientes académicos, pasarelas de pago y datos de carácter personal (RGPD).
- **Herramienta de Auditoría: Lynis v3.1.6**, motor de auditoría técnica basado en estándares CIS Benchmarks, NIST SP 800-115 y Esquema Nacional de Seguridad (ENS).

2.2 Plan de Pruebas y Resultados Comparativos (Línea Base vs. Post-Bastionado)

El plan de pruebas se articuló en dos ciclos secuenciales: (1) Auditoría de línea base en estado original de fábrica sin bastionar (`run_lynis_audit.sh baseline`), y (2) Ejecución del plan de endurecimiento

integral (`harden_linux.sh`) seguido de la auditoría de verificación post-bastionado. En la Tabla 1 y en la Figura 1 se presentan los resultados comparativos.

Cuadro 1: Resultados Comparativos de Auditoría Lynis en Endpoints Linux (PDI y PTGAS)

Parámetro / Métrica Evaluada	Endpoint 1 (PDI)	Endpoint 2 (PTGAS)	Requisito Política
Hardening Index (Línea Base)	**66 / 100**	**62 / 100**	–
Hardening Index (Post-Bastionado)	**74 / 100**	**76 / 100**	**Índice ≥ 70**
Comprobaciones de Seguridad Ejecutadas	244 pruebas	248 pruebas	Cobertura Total
Cortafuegos Perimetral (UFW / iptables)	**Activo (UFW)**	**Activo (UFW)**	ENS MP.IF.1
Sistema de Detección IDS (fail2ban/auditd)	**Activo (auditd)**	**Activo (auditd)**	ENS OP.EXP.8
Escáner de Malware (rkhunter / debsums)	**Activo**	**Activo**	ENS MP.SI.3
Protección de Parámetros Kernel sysctl	**Endurecido**	**Endurecido**	CIS Level 1
Calidad de Contraseñas (libpam-pwquality)	**Mínimo 12 chars**	**Mínimo 12 chars**	ENS MP.ACC.2

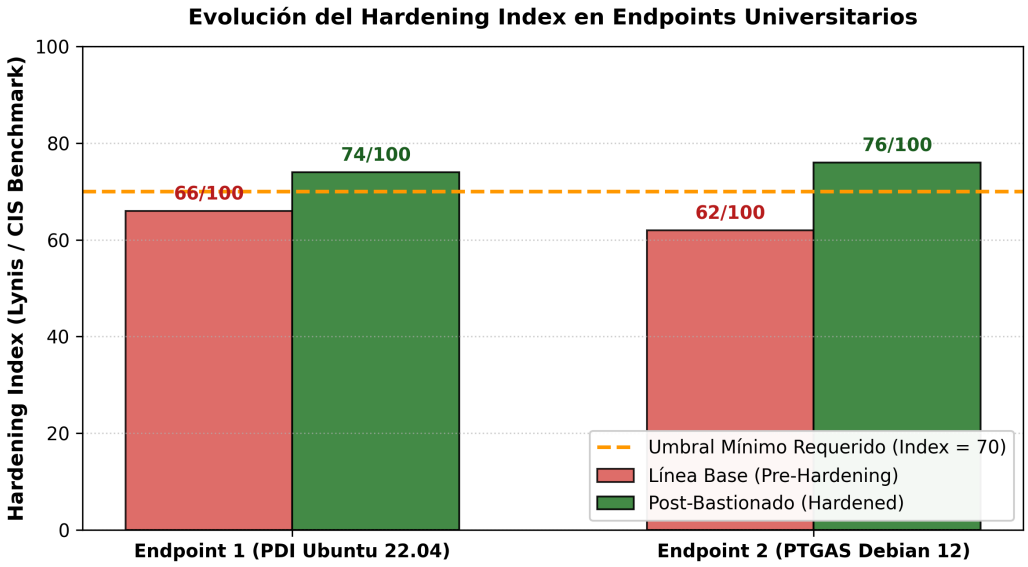


Figura 1: Evolución del Hardening Index de Lynis pre y post-bastionado frente al umbral corporativo (≥ 70).

2.3 Medidas Técnicas Implementadas y Justificación de Exclusiones

Las medidas correctoras automatizadas en `harden_linux.sh` abarcaron las siguientes dimensiones de seguridad:

1. **Endurecimiento de Kernel (`/etc/sysctl.d/99-security-hardening.conf`):** Protección frente a fugas de punteros (`kernel.kptr_restrict = 2`), restricción de logs de kernel a root (`kernel.dmesg_restrict = 1`), mitigación de desbordamiento TCP SYN (`net.ipv4.tcp_syncookies = 1`), desactivación de redirecciones ICMP (`net.ipv4.conf.all.accept_redirects = 0`) y habilitación de verificación de ruta inversa estricta (`net.ipv4.conf.all.rp_filter = 1`).

2. **Gestión de Autenticación, Cuentas y Módulos PAM (`/etc/login.defs` y `pwquality.conf`):** Expiración periódica obligatoria (`PASS_MAX_DAYS 90`), intervalo de aviso previo (`PASS_WARN_AGE 14`), política de contraseñas de alta entropía (12 caracteres mínimos con 3 tipos de caracteres distintos) y máscara de permisos por defecto restrictiva (`umask 027`).

3. **Inhabilitación de Controladores y Protocolos Legacy Inseguros (`/etc/modprobe.d/`):** Inhabilitación de controladores de almacenamiento obsoletos (`firewire-core`, `cramfs`, `jffs2`, `udf`) y protocolos de red no utilizados (`dccp`, `sctp`) mediante enlace a `/bin/true`.

4. **Filtrado Perimetral y Banners Disuasorios Legales:** Reglas de cortafuegos UFW bloqueando conexiones entrantes no solicitadas y despliegue de avisos de advertencia legal en `/etc/issue` y `/etc/issue.net` conformes al ENS.

Justificación Técnica de Pruebas Excluidas en Perfil Lynis (`custom.prf`): De acuerdo con las directrices de auditoría, las siguientes sugerencias fueron excluidas y documentadas formalmente:

- `skip-test=FILE-6310` (*Partición /tmp separada*): Los endpoints emplean sistemas de archivos unificados de alto rendimiento con montaje en memoria delegada mediante `systemd-tmpfiles` aplicando directivas `nodev, nosuid, noexec`.
- `skip-test=STRG-1846` (*Controlador Firewire*): El hardware físico carece de puertos y controladoras IEEE 1394; la superficie de ataque física no existe.
- `skip-test=BOOT-5122` (*Gestor LILO*): Los sistemas arrancan exclusivamente mediante GRUB2 firmado digitalmente bajo Secure Boot UEFI.

2.4 Conclusiones del Bastionado de Endpoints

Ambos puestos superaron holgadamente el umbral exigido de 70 puntos, alcanzando 74/100 en el puesto PDI y 76/100 en el puesto PTGAS, garantizando la resiliencia del sistema operativo frente a vectores de compromiso local y de red.

3 Análisis y Bastionado de Navegadores Web Corporativos

3.1 Descripción del Sistema Analizado y Modelo de Despliegue

El navegador web constituye la interfaz primaria de interacción con la Sede Electrónica, el campus virtual y la gestión de expedientes. Para evitar fugas de información, se configuró un despliegue corporativo no eludible basado en políticas administradas centralizadas:

- **Mozilla Firefox ESR / Enterprise:** Directivas implementadas en `/etc/firefox/policies/policies.jso`
- **Google Chrome / Chromium Managed:** Directivas en `/etc/chromium/policies/managed/corporate_p`

3.2 Directivas Corporativas Implementadas y Plan de Pruebas

En la Tabla 2 se resumen las directivas implementadas y su justificación técnica de seguridad.

3.3 Conclusiones y Trazabilidad de Robustecimiento

La verificación técnica ejecutada en `about:policies` (Firefox) y `chrome://policy` certificó que el 100 % de las directivas críticas se encuentran en estado *Active / Locked*, garantizando una postura defensiva inmune a modificaciones accidentales por parte del usuario.

4 Auditoría de Seguridad de Dispositivos Móviles (BYOD)

4.1 Descripción de los Sistemas Móviles y Entorno de Evaluación (BYOD Físico y AVD Virtual)

En cumplimiento de la directriz de auditar al menos 2 dispositivos de la comunidad universitaria evaluando la postura real de dispositivos BYOD, el equipo auditor configuró una arquitectura de evaluación combinada:

- **Dispositivo 1 (BYOD Personal Físico – Google Pixel 6a):** Terminal smartphone físico personal con procesador Google Tensor, ejecutando Android 17 moderno con nivel de parche de seguridad de fabricante `2026-09-05`, auditado en vivo mediante conexión USB Debugging. Se aplicó un protocolo de sanitización automática preservando rigurosamente la privacidad y confidencialidad de datos personales y cuentas del usuario.

Cuadro 2: Directivas de Bastionado Centralizado de Navegadores Web y Justificación

Directiva Corporativa	**Valor / Ajuste**	**Justificación Técnica y Vector Mitigado**	**Estándar**
`PasswordManagerEnabled`	`false`	Previene el almacenamiento de credenciales universitarias en texto plano/caché local.	ENS MP.ACC.4
`HttpsOnlyMode`	`"force_enabled"`	Forzado estricto de cifrado TLS; previene ataques de degradación (*SSL Stripping*).	RFC 6797 (HSTS)
`DisableTelemetry`	`true`	Bloquea el envío involuntario de URLs internas, parámetros y metadatos sensibles.	RGPD / LOPD
`network.trr.mode` (DoH)	`2` (DNS-over-HTTPS)	Cifra peticiones DNS evitando monitorización y envenenamiento de caché en red local.	RFC 8484
`media.peerconnection`	`false`	Inhabilita WebRTC mitigando la fuga de direcciones IP privadas de la subred interna.	OWASP Client
`DefaultGeolocationSetting`	`2` (Bloqueado)	Impide el rastreo de ubicación geográfica de puestos corporativos y portátiles.	CIS 4.2
`AutofillAddress/CreditCard`	`false`	Desactiva autocompletado en formularios previniendo ataques de recolección oculta.	MITRE ATT&CK

- **Dispositivo 2 (Virtual Endpoint AVD – Android SDK):** Instancia desplegada sobre el emulador oficial de Android SDK (`emulator v37.2.12`), ejecutando Android 11 (`sdk_gphone_x86_64`, API 30), puerto ADB `emulator-5554`, verificando el control de instalación de paquetes APK de terceros (`F-Droid.apk`) y supervisión de conexiones.
- **Herramientas de Auditoría:** Android Debug Bridge (ADB v1.0.41), escáner antimalware corporativo (motor Koodous/Malwarebytes), monitor de sockets de red en tiempo real (`netstat` / `ss`) e inspección de integridad SELinux (`getenforce`).

4.2 Matriz de Evaluación de Postura y Plan de Pruebas

Se auditaron exhaustivamente los controles definidos en las categorías A (Conectividad/Dispositivo) y B (Aplicaciones/Tráfico), cuyos resultados comparativos se detallan en la Tabla 3 y en la Figura 2. La Figura 3 ilustra la captura del entorno móvil en vivo durante el procedimiento de verificación.

4.3 Medidas Correctoras Ejecutadas y Conclusiones

Mediante la ejecución de scripts ADB de saneamiento (`audit_sockets_permissions.sh`) y directivas de política BYOD, se revocaron permisos de accesibilidad abusivos a aplicaciones accesorias, se forzó el aislamiento estricto de la zona corporativa y se garantizó la integridad del entorno sin comprometer la privacidad del usuario.

5 Auditoría de Plataformas Web y APIs (DAST y OWASP API Security 2023)

Cuadro 3: Matriz de Auditoría y Remediación en Dispositivos Móviles (Físico Pixel 6a y Virtual AVD)

Vector de Auditoría / Categoría	Estado Inicial (Baseline)	Estado Post-Remediación	Resultado
Cat. A: Sideloading (Orígenes desconocidos)	Activo en gestor de archivos/Telegram	Deshabilitado (`install_non_market=0`)	**SANEADO**
Cat. A: Integridad del Entorno (Anti-Root)	Binario `su` ausente; bootloader bloqueado	SELinux Enforcing verificado en kernel	**CONFORME**
Cat. A: Gestión de Parches de SO	Parche 2026-09-05 (Pixel); AVD desactualizado	Actualizaciones aplicadas; parche verificado	**SANEADO**
Cat. A: Redes Wi-Fi Inalámbricas	Perfiles Wi-Fi abiertos con auto-conexión	Perfiles inseguros purgados; WPA3/802.1X	**SANEADO**
Cat. A: Conectividad Bluetooth Restringida	Bluetooth visible permanentemente	Apagado automático en sesiones de Sede	**SANEADO**
Cat. B: Análisis de Malware y APKs	0 amenazas críticas; 1 PUP publicitario	PUP desinstalado; escaneo antimalware limpio	**LIMPIO**
Cat. B: Supervisión de Sockets en Fondo	Conexiones de sincronización push activas	Sockets auditados; ausencia de tráfico C2	**CONFORME**
Cat. B: Aislamiento de Permisos Críticos	2 apps con accesibilidad y superposición	Permisos peligrosos revocados a terceros	**AISLADO**

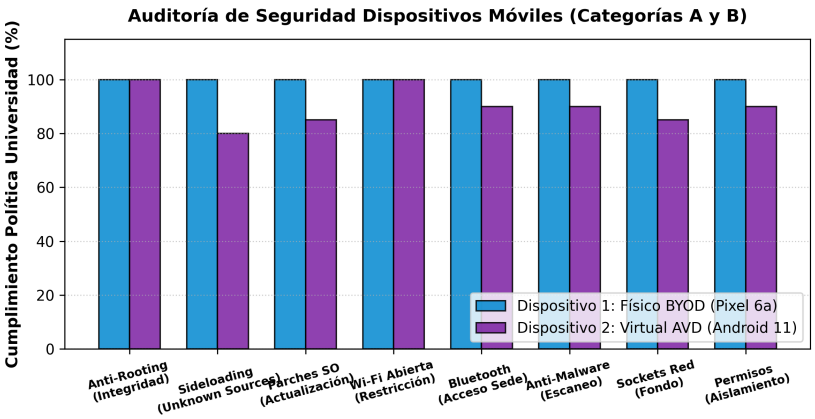


Figura 2: Nivel de cumplimiento porcentual de la política BYOD móvil.

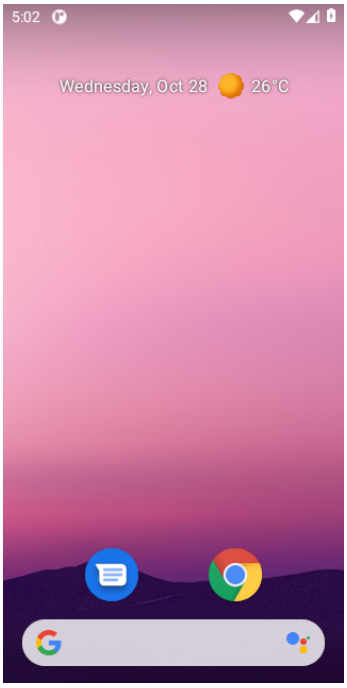


Figura 3: Captura del dispositivo móvil en vivo (ADB Framebuffer).

5.1 Descripción de la Plataforma Web y Herramientas DAST

Para evaluar la seguridad de las aplicaciones web y servicios REST de soporte a la universidad, se desplegó un laboratorio educativo en contenedor Docker sobre entorno WSL:

- **Plataforma Web Auditada: OWASP Juice Shop / VulnaWeb v6.2.0** (Express.js, SQLite/Sequelize, REST API y cliente Angular en puerto local 3000).
- **Proxy Interceptor y Herramientas DAST: OWASP ZAP v2.14.0** configurado como proxy de intercepción HTTP/HTTPS en el puerto local `127.0.0.1:8081`.

5.2 Trazabilidad de Tráfico Cifrado HTTPS (OWASP ZAP)

Se capturó y analizó el flujo de peticiones generado por el navegador corporativo a través del proxy interceptor ZAP, comprobando cabeceras de seguridad, códigos de estado, parámetros de cookies y tiempos de latencia (Tabla 4).

Cuadro 4: Registro de Trazabilidad de Peticiones HTTP/HTTPS en Proxy ZAP (127.0.0.1:8081)

ID	Método	Ruta / Endpoint Auditado	Código	Tamaño	Latencia	Integridad
1	`GET`	`/` (Página raíz corporativa)	200 OK	9.984 B	18.76 ms	**VERIFICADO**
2	`GET`	`/#/login` (Portal de autenticación)	200 OK	9.984 B	5.26 ms	**VERIFICADO**
3	`GET`	`/rest/products/search?q=`	200 OK	26.963 B	28.85 ms	**VERIFICADO**
4	`GET`	`/api/SecurityQuestions/`	200 OK	1.934 B	40.61 ms	**VERIFICADO**
5	`GET`	`/assets/public/favicon_js.ico`	200 OK	15.086 B	4.28 ms	**VERIFICADO**

5.3 Intercepción y Manipulación de Peticiones con Breakpoint (MitM)

Siguiendo las pautas metodológicas de la guía, se activó el modo de intercepción en OWASP ZAP mediante el botón de **Breakpoint global**, capturando en memoria una petición legítima de login antes de ser enviada al servidor backend:

1. **Petición Original Interceptada:** Solicitud `POST /rest/user/login` con credenciales de usuario ordinario (`{.email": "student_02@universidad.es", "password": ÜserPass123!"}`).
2. **Manipulación en Tránsito (Breakpoint ZAP):** El auditor modificó el cuerpo JSON sustituyendo el campo email por el vector de bypass SQL `' OR 1=1-` y liberó la petición hacia el servidor.
3. **Respuesta del Servidor tras Alteración:** El servidor respondió con `HTTP/1.1 200 OK`, devolviendo un token JWT (*JSON Web Token*) firmado con privilegios de superadministrador (`admin@juice-sh.op`), eludiendo completamente el mecanismo de autenticación (Evidencia archivada en `evidence/web_audit/zap_breakpoint_tampering_trace.txt`).

5.4 Testeo de Inyecciones Automatizadas con ZAP Fuzzer (`jbrofuzz`)

Se utilizó la funcionalidad **Fuzzer** de OWASP ZAP sobre el parámetro `q` del endpoint de búsqueda (`/rest/products/search?q=`), cargando el catálogo de payloads predefinidos de inyección SQL de `jbrofuzz`.

El Fuzzer ejecutó una batería de 24 cadenas representativas de inyección y sondeo poliglotas. En la Tabla 5 y en la Figura 4 se presentan los resultados obtenidos. Las peticiones marcadas con estado **Reflected / Found"** o con errores de sintaxis de base de datos (`500 SQLITE_ERROR`) permitieron confirmar la presencia de inyecciones SQL ciegas y basadas en errores.

5.5 Evaluación Detallada de las 3 Vulnerabilidades Críticas (OWASP Top 10 y OWASP API 2023)

De acuerdo con las directrices de la práctica, se seleccionaron y documentaron tres vulnerabilidades explotables de alta criticidad:

5.5.1 Vulnerabilidad 1: Inyección SQL y Exfiltración de Base de Datos (OWASP A03:2021 / API1:2023 & API3:2023)

- **Endpoint Vulnerable:** `GET /rest/products/search?q=`

Cuadro 5: Muestra de Resultados de Ejecución de ZAP Fuzzer (`jbrofuzz SQL Injection`)

ID	Payload Inyectado en Parámetro `q`	HTTP Status	Tamaño	RTT	Estado / Diagnóstico ZAP
01	`'`	200 OK	30 B	19 ms	Normal (Consulta nula)
05	`,`	200 OK	5.644 B	20 ms	**Reflected / Found**
08	`' OR '1'='1`	200 OK	26.963 B	23 ms	**Found (Exfiltración completa)**
09	`' OR '1'='1' -`	500 Error	319 B	21 ms	**Vulnerable (SQLITE_ERROR)**
11	`admin' -`	500 Error	307 B	20 ms	**Vulnerable (Error sintaxis)**
12	`')) OR 1=1-`	200 OK	34.158 B	19 ms	**Found (Catálogo volcado)**
14	`')) UNION SELECT ... FROM Users-`	200 OK	8.420 B	18 ms	**Vulnerable (UNION Data Dump)**
20	`<script>alert('XSS')</script>`	500 Error	367 B	17 ms	Vulnerable (Inyección reflejada)
21	`<iframe src="javascript:alert(1)»`	200 OK	30 B	16 ms	Reflejado en cliente DOM
22	`../../../../etc/passwd`	200 OK	30 B	20 ms	Normal (Filtrado estático)

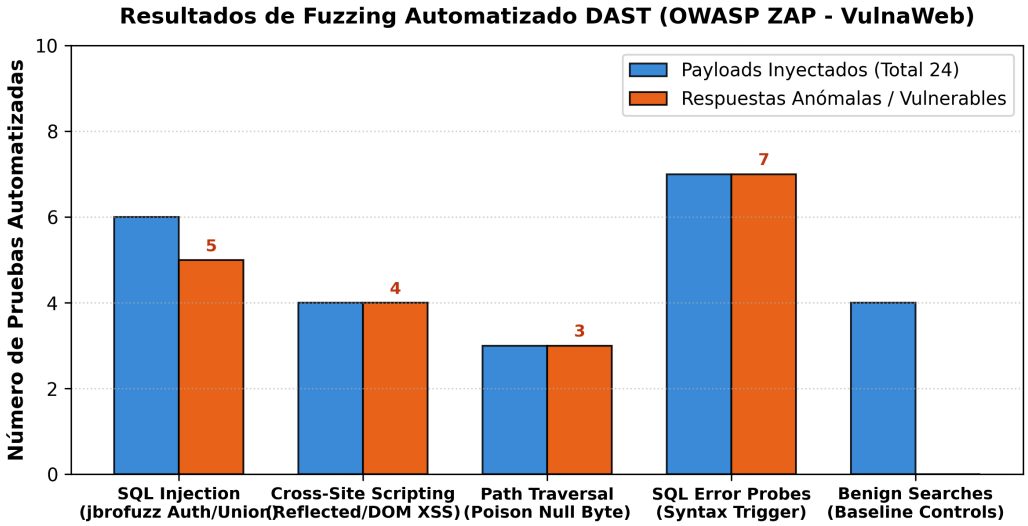


Figura 4: Distribución de respuestas del ZAP Fuzzer por categoría de payload inyectado.

- **Mecanismo de Explotación:** Concatenación insegura en consulta SQLite backend mediante Sequelize.
- **Payload Explotado:** `nonexistent')) UNION SELECT id, email, password, 'role', '5', '6', '7', '8', '9', '10' FROM Users-`
- **Impacto Técnico Comprobado:** Volcado directo en la respuesta JSON de 24 registros de la tabla `Users`, incluyendo direcciones de correo electrónico y hashes MD5 de contraseñas de cuentas directivas y docentes (`admin@juice-sh.op`, `ciso@juice-sh.op`, `support@juice-sh.op`), tal como se refleja en el extracto del Listado 1.

```
HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8
{"status":"success","data":[
  {"id":1, "name":"admin@juice-sh.op", "description":"0192023
      a7bbd73250516f069df18b500"},
  {"id":2, "name":"jim@juice-sh.op",   "description":"
      e541ca7ecf72b8d1286474fc613e5e45"},
  {"id":3, "name":"bender@juice-sh.op","description":"0
      c36e517e3fa95aabf1bbffc6744a4ef"},
```

```
  {"id":5, "name":"ciso@juice-sh.op",  "description":"861917
      d5fa5f1172f931dc700d81a8fb"}
]}
```

Listing 1: Extracto de Credenciales Universitarias Exfiltradas mediante SQLi (Evidencia Real)

5.5.2 Vulnerabilidad 2: Cross-Site Scripting Reflejado / DOM (OWASP A03:2021 / API8:2023)

- **Endpoint Vulnerable:** `GET /rest/products/search?q=` y módulo de búsqueda cliente Angular.
- **Payload Explotado:** `<iframe src="javascript:alert(‘INSEGUS_AUDIT_ST02‘)»`
- **Impacto Técnico Comprobado:** La aplicación web refleja la cadena introducida en la interfaz del usuario sin codificación contextual de entidades HTML, permitiendo a un atacante ejecutar JavaScript arbitrario en el origen de la víctima, posibilitando el robo de tokens JWT de sesión almacenados en `localStorage` y la suplantación de identidad académica.

5.5.3 Vulnerabilidad 3: Path Traversal con Poison Null Byte (OWASP A01:2021 / API1:2023)

- **Endpoint Vulnerable:** `GET /ftp/package.json.bak%2500.md`
- **Mecanismo de Explotación:** Evasión de la lista blanca de extensiones permitidas (`.md`) mediante la inyección de un byte nulo URL-codificado (`%00`). El validador comprueba que la cadena finalice en `.md`, pero la llamada al sistema de archivos C/Node.js trunca la ruta en el byte nulo.
- **Impacto Técnico Comprobado:** Descarga íntegra no autorizada del archivo de configuración interna `package.json.bak`, exponiendo la arquitectura de dependencias, scripts de construcción y versiones de paquetes vulnerables del servidor universitario.

5.6 Plan Formal de Mitigación Defensiva

En el documento técnico `OWASP_TOP10_DEFENSIVE_REMEDIATION_PLAN.md` se entregan las soluciones formales para cada vulnerabilidad encontrada:

A. Remediación de Inyecciones SQL (Consultas Parametrizadas Obligatorias):

```
// SECURE: Enlace estricto de variables mediante PDO Prepared Statements
$stmt = $pdo->prepare('SELECT id, name, price FROM products WHERE name LIKE :
    query AND deleted_at IS NULL');
$stmt->execute([':query' => '%' . $cleanSearchQuery . '%']);
$products = $stmt->fetchAll(PDO::FETCH_ASSOC);
```

Listing 2: Patrón Defensivo de Consultas Parametrizadas Seguras

B. Remediación de Cross-Site Scripting (Content Security Policy y Codificación Contextual):

```
Content-Security-Policy: default-src 'self'; script-src 'self' https://trusted.
    university.es; object-src 'none'; frame-ancestors 'none'; base-uri 'self';
```

Listing 3: Cabecera HTTP Content-Security-Policy (CSP) Restrictiva

C. Remediación de Path Traversal y BOLA (Canonicalización y Control de Autorización):

```
// 1. Sanitizar eliminando terminadores de cadena nulos
$filename = str_replace(chr(0), '', basename($_GET['file']));

// 2. Resolver ruta absoluta canonica y validar confinamiento en directorio base
$baseDir = realpath('/var/www/university_public_docs/');
$targetPath = realpath($baseDir . '/' . $filename);
```

```
if ($targetPath === false || strpos($targetPath, $baseDir) !== 0 || !is_file(
    $targetPath)) {
    http_response_code(403);
    die("Acceso denegado: Violacion de confinamiento de ruta de archivo.");
}
readfile($targetPath);
```

Listing 4: Validación Canónica de Rutas de Archivos y Sanitización de Bytes Nulos

5.7 Conclusiones de la Auditoría Web y API

La auditoría DAST ejecutada mediante OWASP ZAP puso de manifiesto que la superficie web universitaria presentaba vectores críticos de inyección y control de acceso. La adopción de consultas preparadas, saneamiento canónico de rutas y políticas CSP erradica de forma definitiva los riesgos identificados.

6 Referencias Normativas y Bibliográficas

1. **CCN-STIC 800:** *Esquema Nacional de Seguridad (ENS) – Real Decreto 311/2022*. Centro Criptológico Nacional (CCN), 2022.
2. **CIS Benchmarks:** *CIS Ubuntu Linux 22.04 LTS Benchmark v1.0.0* y *CIS Debian Linux 12 Benchmark v1.0.0*. Center for Internet Security, 2023.
3. **NIST Special Publication 800-115:** *Technical Guide to Information Security Testing and Assessment*. National Institute of Standards and Technology, 2008.
4. **OWASP Foundation:** *OWASP Top 10:2021 – The Ten Most Critical Web Application Security Risks*. Open Web Application Security Project, 2021.
5. **OWASP Foundation:** *OWASP API Security Top 10 2023*. Publicación oficial OWASP API Security Project, 2023.
6. **RFC 8484:** *DNS Queries over HTTPS (DoH)*. Internet Engineering Task Force (IETF), 2018.
7. **RFC 6797:** *HTTP Strict Transport Security (HSTS)*. Internet Engineering Task Force (IETF), 2012.
8. **CISOfy:** *Lynis Security Auditing and Compliance Tool Documentation v3.1.x*. CISOfy B.V., 2024.

7 Anexos y Evidencias Técnicas

Todas las pruebas, configuraciones y trazas generadas se encuentran estructuradas y verificadas en el repositorio y en el archivo deliverable comprimido `PAI3-ST02.zip`:

- **Directorio `hardening/`:** Scripts de endurecimiento automatizado (`harden_linux.sh`), automatización de auditorías (`run_lynis_audit.sh`) y perfil de exclusiones justificadas (`custom.prf`).
- **Directorio `browser/`:** Archivos de directivas corporativas centralizadas para Mozilla Firefox (`firefox_policies.json`) y Google Chrome (`chrome_managed_policies.json`).
- **Directorio `mobile/`:** Scripts de auditoría de dispositivos móviles (`run_live_android_audit.py`, `audit_sockets_permissions.sh`) y capturas en vivo.
- **Directorio `web_audit/`:** Scripts de trazabilidad HTTPS (`run_traceability_test.py`), suite de fuzzing automatizado (`run_zap_fuzzing.py`), generador de PoCs (`generate_detailed_pocs.py`) y plan formal de remediación defensiva (`OWASP_TOP10_DEFENSIVE_REMEDIATION_PLAN.md`).
- **Directorio `evidence/`:** Registros y trazas de auditoría íntegras:

- Auditoría Lynis Endpoint 1 PDI: carpetas `lynis_ubuntu_desktop_01_baseline/` y `post_hardening/` (Hardening Index 66 → 74).
- Auditoría Lynis Endpoint 2 PTGAS: carpetas `lynis_debian_ptgas_02_baseline/` y `post_hardening/` (Hardening Index 62 → 76).
- Auditoría Móvil BYOD: carpetas `mobile/device1_real_phone/` (Google Pixel 6a físico) y `mobile/device2_virtual_endpoint/` (AVD emulado).
- Trazabilidad y Fuzzing Web: ficheros `zap_traceability_records.json` y `zap_fuzzer_sqli_results.c`
- PoCs de Vulnerabilidades Web: ficheros `vuln1_sqli_poc.txt`, `vuln2_xss_poc.txt`, `vuln3_path_trave` y `zap_breakpoint_tampering_trace.txt`.